

الوحدة 14: التحكم في الوصول (Access Control)

أنظمة التحكم في الوصول

RBAC (Role-Based Access Control): يمنح الصلاحيات بناءً على دور المستخدم في المؤسسة (مثل: مدير، محاسب، مهندس). الأكثر شيوعاً في الشركات.

ABAC (Attribute-Based Access Control): يمنح الصلاحيات بناءً على سمات (Attributes) مثل: الموقع، الوقت، جهاز المستخدم، مستوى التصنيف. أكثر مرونة من RBAC.

MAC (Mandatory Access Control): تستخدمه الأنظمة الحساسة (العسكرية، الحكومية). يتم تعيين تسميات حساسية (Labels) للملفات والمستخدمين. المستخدم لا يعدل الصلاحيات.

DAC (Discretionary Access Control): مالك الملف يتحكم في صلاحياته. المستخدم يمنح أو يسحب الصلاحيات للآخرين. مستخدم في Windows و Linux.

ACLs (قوائم التحكم في الوصول)

ACL (Access Control List): قائمة تحدد من أو ما الذي يُسمح له بالوصول إلى مورد معين وما هي الإجراءات المسموحة (قراءة، كتابة، تنفيذ). تستخدم في الشبكات (Cisco ACLs) وأنظمة التشغيل.

مثال: إدارة صلاحيات الملفات في Windows باستخدام **icacls**

```
icacls C:\Users\Public\Documents /grant "Everyone":(R,W)
```

الشرح جزءاً جزءاً:

icacls أداة سطر أوامر لعرض وتعديل صلاحيات الملفات والمجلدات في Windows.

C:\Users\Public\Documents المسار المستهدف.

/grant/ يمنح صلاحية جديدة.

"Everyone" المستخدم أو المجموعة المستهدفة.

(R,W) الصلاحيات: R = قراءة، W = كتابة.

يمكنك استخدام **icacls filename** (بدون خيارات) لعرض ACL الحالية للملف.

مثال: إدارة صلاحيات الملفات في Linux باستخدام **chmod**

```
chmod 755 script.sh
```

الشرح جزءاً جزءاً:

chmod أمر تغيير صلاحيات الملف (Change Mode).

755 التمثيل الثماني (Octal):

$rwX = 7$ (مالك الملف: قراءة + كتابة + تنفيذ)

$r-X = 5$ (المجموعة: قراءة + تنفيذ)

$r-X = 5$ (الأخرون: قراءة + تنفيذ)

يمكنك أيضاً استخدام `chmod u+x script.sh` لإضافة إذن تنفيذ للمالك فقط.

إدارة الحسابات (Account Management)

تتضمن: إنشاء وتعطيل وحذف حسابات المستخدمين، تطبيق سياسات كلمات المرور، مبدأ الامتياز الأقل (Least Privilege)، مراجعة الحسابات بشكل دوري.

مبدأ Least Privilege: يمنح المستخدم الحد الأدنى من الصلاحيات اللازمة لأداء مهامه فقط. إذا كان الموظف يحتاج فقط للقراءة، لا تمنحه صلاحية الكتابة.

مثال: سياسات الحسابات في Windows

```
net accounts
```

الشرح: يعرض إعدادات سياسات الحسابات في Windows: حد كلمة المرور (Max Password Age)، حد القفل (Lockout Threshold)، مدة القفل (Lockout Duration)، إلخ. استخدمه لمراجعة وتطبيق سياسات أمان قوية.

(PAM (Privileged Access Management

إدارة ومراقبة الحسابات المميزة (Admin Accounts) لتقليل مخاطر سوء الاستخدام. تشمل:

- **(Just-in-Time (JIT:** منح صلاحيات مميزة مؤقتاً فقط عند الحاجة.
- **Session Monitoring:** تسجيل ومراقبة جلسات المديرين.
- **Password Vaulting:** تخزين كلمات مرور المديرين في خزانة مشفرة.
- **Credential Rotation:** تغيير كلمات المرور تلقائياً وبشكل دوري.

أهمية PAM: الحسابات المميزة هي الهدف الأكبر للمهاجمين، لأنها تمنح وصولاً غير مقيد للنظام. PAM يقلل من سطح الهجوم.

(Quick Quiz (MCQ

1. Which access control model assigns permissions based on job function ?

- a) DAC
- b) MAC
- c) RBAC
- d) ABAC

Answer: c

:The `icacls` command on Windows is used to .2

- a) View processes
- b) Manage file/folder permissions
- c) Manage user accounts
- d) View network adapters

Answer: b

:The Principle of Least Privilege means .3

- a) Users get full access
- b) Users receive only the minimum access required to perform their job
- c) No access at all
- d) Access is always permanent

Answer: b

?Which access control model uses security labels and clearance levels .4

- a) DAC
- b) RBAC
- c) MAC
- d) ABAC

Answer: c

?(What is the primary purpose of PAM (Privileged Access Management .5

- a) Managing standard user accounts
- b) Controlling and auditing privileged account access
- c) Encrypting network traffic
- d) Blocking malware

Answer: b